Cybersecurity AI Agent: Framework Research and Architecture Design

Author: Manus AI **Date:** April 5, 2026

Executive Summary

The cybersecurity landscape is undergoing a fundamental transformation driven by the convergence of Artificial Intelligence, Large Language Models (LLMs), and autonomous agent architectures. This report presents a thorough analysis of the existing ecosystem of cybersecurity AI frameworks, tools, and platforms — spanning threat detection, vulnerability assessment, incident response, threat intelligence, SIEM integration, and the emerging class of LLM-based security agents. Drawing on these findings, the report proposes a comprehensive, multi-layered architecture for an autonomous Cybersecurity AI Agent that integrates deeply with enterprise security infrastructure while maintaining robust governance and human oversight.

1. Introduction

The volume and sophistication of cyber threats have grown exponentially, far outpacing the capacity of human-only security operations centers (SOCs). According to the SANS Institute, only 45% of organizations currently leverage AI in their detection workflows, yet 88% anticipate that AI will become central to their cybersecurity strategy in the near term [1]. This gap between aspiration and adoption underscores the urgent need for well-architected AI systems that can augment — and in some cases autonomously execute — the work of security analysts.

This report is structured in two major parts. The first part surveys the current state of AI adoption across the key domains of cybersecurity, examining both commercial and open-source tools, the AI/ML techniques they employ, and the standards they rely on. The second part synthesizes these findings into a proposed architecture for a

Cybersecurity AI Agent, complete with system diagrams, technology stack recommendations, and deployment considerations.

---

2. Research and Analysis of Existing Cybersecurity AI Frameworks

2.1 Threat Detection and Endpoint Security

Traditional signature-based detection systems, while still valuable for known threats, are fundamentally unable to identify novel or polymorphic attacks. Modern AI-powered security tools address this limitation by learning what constitutes “normal” behavior and flagging deviations in real time. This shift from rule-based to behavioral detection represents one of the most mature applications of AI in cybersecurity [1].

The commercial landscape is dominated by platforms that combine deep learning with endpoint telemetry. **CrowdStrike Falcon** and **SentinelOne Singularity** both employ behavioral analytics and machine learning to deliver autonomous Endpoint Detection and Response (EDR), capable of identifying and containing threats without human intervention. **Darktrace** takes a distinctive approach with its “Enterprise Immune System,” which uses unsupervised machine learning to model the unique “pattern of life” for every user and device on a network. When anomalies are detected, Darktrace’s Antigena module can autonomously neutralize threats in real time [1]. **Vectra AI** focuses on network-level detection, applying AI to identify attacker behaviors across cloud, data center, and enterprise environments.

On the open-source side, established frameworks such as **Snort** and **Suricata** continue to serve as the backbone of many network intrusion detection systems (NIDS). While historically rule-based, both are increasingly being extended with machine learning plugins and Lua scripting interfaces. **Zeek** (formerly Bro) excels as a network analysis framework whose rich log output serves as an ideal feature source for downstream ML models. **Wazuh** has emerged as a comprehensive open-source platform that combines SIEM, EDR, and compliance monitoring capabilities.

The table below summarizes the key AI techniques employed across threat detection tools:

AI/ML Technique	Application in Threat Detection	Example Tools
Unsupervised anomaly detection	Baseline behavior modeling, outlier identification	Darktrace, Vectra AI
Deep learning (CNNs, RNNs)	Malware classification, sequence-based behavioral analysis	CrowdStrike, SentinelOne
Natural Language Processing	Log analysis, threat report parsing	Elastic Security, Splunk
Graph neural networks	Network traffic relationship analysis	Vectra AI
Reinforcement learning	Adaptive detection policy optimization	Research-stage tools

2.2 Vulnerability Assessment and Penetration Testing

AI is transforming vulnerability management from a periodic, scan-and-patch cycle into a continuous, risk-prioritized discipline. Traditional scanners produce overwhelming volumes of findings; AI helps organizations focus on the vulnerabilities that matter most.

Tenable Nessus remains the industry-standard vulnerability scanner, now enhanced with ML-based prioritization that goes beyond static CVSS scores to predict real-world exploitability. **Qualys VMDR** and **Rapid7 InsightVM** offer similar cloud-based vulnerability management with ML-driven risk scoring. In the cloud security domain, **Wiz** has pioneered an agentless approach that uses AI to correlate risks across the entire cloud stack — from code to runtime — without requiring software installation on individual virtual machines [1].

Open-source alternatives include **OpenVAS** (maintained by Greenbone), which provides comprehensive vulnerability scanning, and **Nuclei**, a fast, template-based scanner widely used for automated security testing. **OWASP ZAP** remains the go-to open-source tool for web application security assessment.

Perhaps the most disruptive development in this domain is the rise of **LLM-powered autonomous penetration testing**. **PentestGPT** harnesses the domain knowledge embedded in large language models to automate penetration testing workflows that traditionally required extensive human expertise [2]. The academic research framework **HackSynth** demonstrates a particularly elegant dual-module architecture: a **Planner** module that generates executable commands based on the current state,

and a **Summarizer** module that parses command output and updates the agent's understanding of the target environment. This iterative loop enables HackSynth to autonomously solve Capture The Flag (CTF) challenges across domains including web exploitation, cryptography, reverse engineering, and forensics [3]. Other notable systems include **AutoAttacker**, which automates exploitation via the Metasploit framework, and **Enigma**, considered state-of-the-art for its ability to handle interactive terminal sessions autonomously.

2.3 Incident Response and SOAR Platforms

Security Orchestration, Automation, and Response (SOAR) platforms represent the operational backbone of modern SOCs, and AI is increasingly central to their value proposition. These platforms integrate with hundreds of security tools to automate alert triage, investigation, and response workflows through programmable playbooks.

Splunk SOAR (formerly Phantom) offers integration with over 300 third-party tools and supports more than 2,800 automated actions. Its visual playbook editor allows analysts to design complex response workflows without writing code, while machine learning helps prioritize and route alerts [4]. **Palo Alto Cortex XSOAR** provides a comprehensive platform that unifies case management, automation, real-time collaboration (via its "war room" feature), and threat intelligence management. Its marketplace offers over 900 content packs for integrations, and AI assists in identifying malicious behavior and recommending responses [5]. **IBM QRadar SOAR** (formerly Resilient) differentiates itself with dynamic, adaptable playbooks and a dedicated breach response module that includes built-in guidance for over 200 global privacy regulations [6].

On the open-source side, **TheHive** is a widely adopted incident response platform designed for SOCs and CSIRTs, offering collaborative case management and integration with threat intelligence tools. **Shuffle** provides an open-source SOAR platform built around OpenAPI, with AI-powered features that help analysts generate automation workflows from natural language descriptions of their intent [7].

The following table compares the major SOAR platforms:

Platform	Type	Key Differentiator	Integrations	AI Capabilities
Splunk SOAR	Commercial	Visual playbook editor, Splunk ES integration	300+ tools, 2,800+ actions	ML alert prioritization
Cortex XSOAR	Commercial	War room collaboration, marketplace	900+ content packs	AI behavior analysis
IBM QRadar SOAR	Commercial	Breach response for 200+ regulations	IBM Security App Exchange	AI-driven dynamic playbooks
TheHive	Open-source	Collaborative case management	MISP, Cortex analyzers	Limited native AI
Shuffle	Open-source	OpenAPI-based, AI workflow builder	Broad via OpenAPI	NL-based automation generation

2.4 Threat Intelligence Platforms

Threat intelligence platforms (TIPs) aggregate, correlate, and disseminate information about cyber threats. AI plays a critical role in processing the vast volumes of unstructured data — from dark web forums to government advisories — that feed these platforms.

Among open-source platforms, **MISP** (Malware Information Sharing Platform) is the foundational standard for collaborative threat intelligence sharing. It supports STIX 1.x and 2.x formats, provides automatic correlation of indicators, and offers a modular architecture extensible through community-developed modules, including the `misp-ml` project for machine learning classification [8]. **OpenCTI**, developed by Filigran, builds on the STIX 2.1 data model to provide a unified platform for organizing, visualizing, and sharing threat intelligence. It is actively incorporating AI-powered features including natural language querying, automated report generation, and AI-assisted file analysis [9].

On the commercial side, **Recorded Future** is distinguished by its extensive data collection and its “Intelligence Graph,” which maps billions of associations between threat data points in real time. The platform uses NLP to extract intelligence from unstructured text in multiple languages and employs predictive analytics to identify

emerging threats before they materialize [10]. **Mandiant** (a Google subsidiary) brings a unique perspective informed by over 200,000 hours per year of incident response work, curated by more than 500 analysts. It leverages Google's Gemini AI to provide AI-powered summaries of complex threat intelligence [11]. **ThreatConnect** offers its Collective Analytics Layer (CAL), which uses generative AI, NLP, and machine learning to surface actionable insights from large volumes of data [12].

A critical enabler across all these platforms is the adoption of interoperability standards. **STIX** (Structured Threat Information Expression) provides a standardized language for describing cyber threat information, while **TAXII** (Trusted Automated Exchange of Intelligence Information) defines the transport protocol for sharing that information. These standards are essential for any cybersecurity AI agent that needs to consume and produce threat intelligence.

2.5 SIEM and AI Integration

Security Information and Event Management (SIEM) platforms serve as the central nervous system of security operations, aggregating logs and alerts from across the enterprise. AI integration is transforming SIEMs from passive log repositories into proactive threat detection engines.

Microsoft Sentinel is a cloud-native SIEM that provides built-in ML analytics rules, User and Entity Behavior Analytics (UEBA), and deep integration with the broader Microsoft security ecosystem, including Security Copilot [13]. **Splunk Enterprise Security** offers the Machine Learning Toolkit (MLTK), enabling security teams to build and deploy custom ML models for anomaly detection and threat hunting directly within the platform. **Elastic Security**, built on the open-source Elastic Stack, provides ML-powered anomaly detection alongside a flexible detection rules engine. **Wazuh**, as an open-source alternative, combines SIEM capabilities with XDR features and supports integration with external ML tools for enhanced analytics.

The primary AI integration patterns observed across modern SIEMs include User and Entity Behavior Analytics (UEBA) for detecting insider threats and compromised accounts, ML-based alert correlation and prioritization to reduce analyst fatigue, automated threat hunting using behavioral baselines, and increasingly, natural language query interfaces that allow analysts to interrogate their data conversationally.

2.6 LLM-Based Security Agents and Autonomous Frameworks

The most transformative development in cybersecurity AI is the emergence of autonomous, LLM-based security agents. These systems go beyond simple chatbot interfaces to act as intelligent collaborators — and in some cases, autonomous operators — within security workflows.

Microsoft Security Copilot is the most prominent enterprise offering in this category. It combines a specialized security language model with Microsoft's global threat intelligence (informed by more than 100 trillion daily signals) to deliver agentic automation across Microsoft Defender XDR, Sentinel, Intune, Entra, and Purview. Security Copilot agents are designed to autonomously handle high-volume tasks such as phishing triage, data security investigation, and identity management, while learning from analyst feedback to adapt to organizational workflows [13].

Research into agentic cybersecurity architectures reveals a consistent design pattern centered on multi-agent collaboration. As described by Morales Aguilera, an effective agentic security system comprises several distinct, interconnected agents [14]:

> *"An agentic architecture is structured much like a well-coordinated team, with each member possessing specific expertise and tools. At its core, this system comprises several distinct, yet interconnected, agents: the Orchestrator Agent serves as the central command… the Analysis Agent is where the raw power of the LLM is directly applied… the Search Agent specializes in external information gathering… and the Action Agent is the system's executor."*

This pattern — an Orchestrator that plans and delegates, specialized agents that analyze and enrich, and an Action agent that executes — forms the foundation of the architecture proposed in this report. Key agent frameworks that support building such systems include **LangGraph** (for stateful, multi-agent workflows), **CrewAI** (for role-based multi-agent orchestration), and the **OpenAI Agents SDK** (a lightweight Python framework for tool-using agents).

2.7 Governance Frameworks and Standards

Deploying AI in cybersecurity demands adherence to established governance frameworks to ensure safety, reliability, and regulatory compliance. The **NIST AI Risk Management Framework (AI RMF)** provides a structured, voluntary approach to identifying, assessing, and responding to AI risks [15]. The **OWASP LLM Top-10**

addresses the ten most critical vulnerabilities in LLM applications, including prompt injection, data leakage, and insecure output handling [16]. **MITRE ATLAS** (Adversarial Threat Landscape for AI Systems) offers a knowledge base of adversarial tactics and techniques specifically targeting AI systems, supporting threat modeling and red teaming [17]. **Google's Secure AI Framework (SAIF)** provides end-to-end guidance for securing the entire AI lifecycle, from data collection through deployment [18]. The international standard **ISO/IEC 42001** establishes requirements for AI management systems.

Zero Trust Architecture is particularly relevant for AI agents, as it mandates continuous verification and least-privilege access at every stage of interaction — principles that must extend to the AI system itself. Furthermore, **MLSecOps** practices integrate security into the ML operations lifecycle, addressing threats such as data poisoning, model inversion, and evasion attacks through frameworks like SLSA (Supply-chain Levels for Software Artifacts) and Sigstore [18].

---

3. Cybersecurity AI Agent Architecture Design

Based on the comprehensive research presented above, this section proposes a multi-layered, multi-agent architecture for a Cybersecurity AI Agent. The design prioritizes modularity, scalability, deep integration with existing security infrastructure, and robust governance.

3.1 Overall System Architecture

The architecture is organized into six distinct layers, each with clearly defined responsibilities and interfaces. This layered approach ensures separation of concerns, enables independent scaling of components, and provides multiple points for security controls and human oversight.

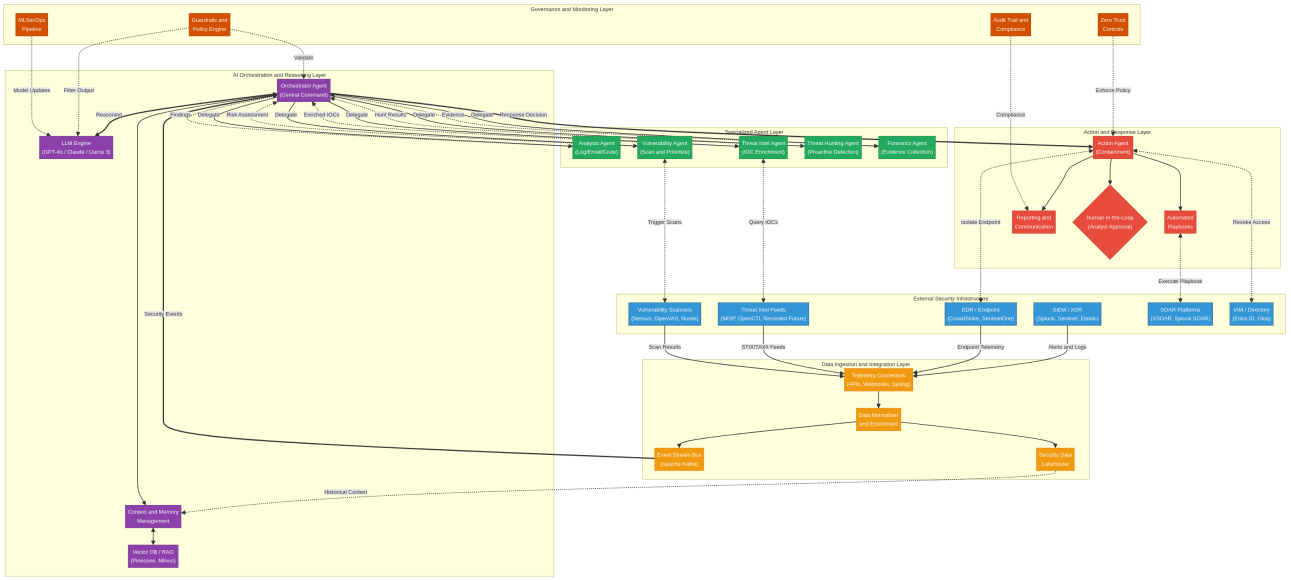

Figure 1: Cybersecurity AI Agent — Full System Architecture. The diagram illustrates the six layers of the system: External Security Infrastructure (blue), Data Ingestion and Integration (orange), AI Orchestration and Reasoning (purple), Specialized Agent Layer (green), Action and Response (red), and Governance and Monitoring (dark orange). Arrows indicate the flow of data and control between components.

3.2 Key Modules and Components

Layer 1: External Security Infrastructure

This layer represents the existing enterprise security tools that the AI agent integrates with. It is not built as part of the agent itself but rather serves as the source of telemetry and the target of automated actions. Key integration points include SIEM/XDR platforms (Splunk, Microsoft Sentinel, Elastic Security), EDR solutions (CrowdStrike Falcon, SentinelOne), threat intelligence feeds (MISP, OpenCTI, Recorded Future via STIX/TAXII), vulnerability scanners (Nessus, OpenVAS, Nuclei), SOAR platforms (Cortex XSOAR, Splunk SOAR, Shuffle), and Identity and Access Management directories (Microsoft Entra ID, Okta).

Layer 2: Data Ingestion and Integration Layer

This layer acts as the sensory input for the AI agent, continuously collecting, normalizing, and routing security telemetry from the external infrastructure.

The **Telemetry Connectors** module provides pre-built and configurable connectors that ingest data via APIs, webhooks, and Syslog from SIEMs, EDRs, and other security tools. The **Data Normalizer and Enrichment Pipeline** standardizes disparate data

formats into a common schema (aligned with standards such as the Open Cybersecurity Schema Framework, OCSF) and performs initial enrichment, such as GeoIP lookups and asset tagging. The **Event Stream Bus**, implemented using Apache Kafka, provides a high-throughput, fault-tolerant backbone for real-time event routing to the Orchestration Layer. The **Security Data Lakehouse** stores historical logs, telemetry, and processed intelligence for long-term analysis, model training, and compliance purposes.

Layer 3: AI Orchestration and Reasoning Layer (Core Brain)

This is the central intelligence of the system, responsible for strategic planning, contextual reasoning, and task delegation. It is the layer that most directly leverages the capabilities of large language models.

The **Orchestrator Agent** is the primary LLM-powered controller. Upon receiving a security event from the Event Stream Bus, it formulates an investigation strategy using Chain-of-Thought reasoning. It decomposes complex security incidents into discrete sub-tasks and delegates them to the most appropriate specialized agents. After receiving findings from all delegated agents, it synthesizes the results into a holistic threat assessment and determines the appropriate response strategy.

The **Context and Memory Management** module implements Retrieval-Augmented Generation (RAG) to provide the Orchestrator and specialized agents with relevant context. It maintains short-term memory (the current incident's evolving state) and retrieves long-term memory (historical incident patterns, organization-specific baselines, and curated threat intelligence) from a **Vector Database** (e.g., Pinecone, Milvus, or ChromaDB). This RAG-based approach ensures that the LLM's reasoning is grounded in factual, organization-specific data rather than relying solely on its pre-trained knowledge.

The **LLM Engine** provides the foundational reasoning capabilities. A hybrid model strategy is recommended: large, general-purpose models (e.g., GPT-4o or Claude 3.5 Sonnet) for complex orchestration and planning tasks, and smaller, domain-specific or locally deployed models (e.g., Meta Llama 3) for tasks involving highly sensitive data that must not leave the organization's infrastructure.

Layer 4: Specialized Agent Layer

This layer comprises a swarm of specialized, tool-equipped agents that execute the Orchestrator's directives. Each agent is an LLM-powered module with access to a specific set of tools and domain knowledge.

Agent	Responsibility	Tools and Integrations
Analysis Agent	Deep textual and behavioral analysis of logs, emails, code snippets, and scripts. Extracts IoCs and identifies anomalous patterns.	Log parsers, YARA rules, code analysis engines
Threat Intel Agent	Queries external databases and OSINT sources to enrich IoCs and validate threat severity.	MISP, OpenCTI, VirusTotal, Shodan (via STIX/TAXII and APIs)
Vulnerability Agent	Interfaces with scanning tools to assess the exploitability and business impact of identified vulnerabilities.	Nessus, OpenVAS, Nuclei, CVE databases
Threat Hunting Agent	Proactively searches for indicators of compromise and attacker behaviors that have not triggered automated alerts.	SIEM query APIs, EDR telemetry, MITRE ATT&CK mappings
Forensics Agent	Collects and preserves digital evidence for post-incident analysis and potential legal proceedings.	Disk imaging tools, memory analysis (Volatility), packet capture analysis

All specialized agents return their findings to the Orchestrator in a structured JSON format, ensuring seamless machine-to-machine communication and enabling the Orchestrator to synthesize diverse inputs into a coherent assessment.

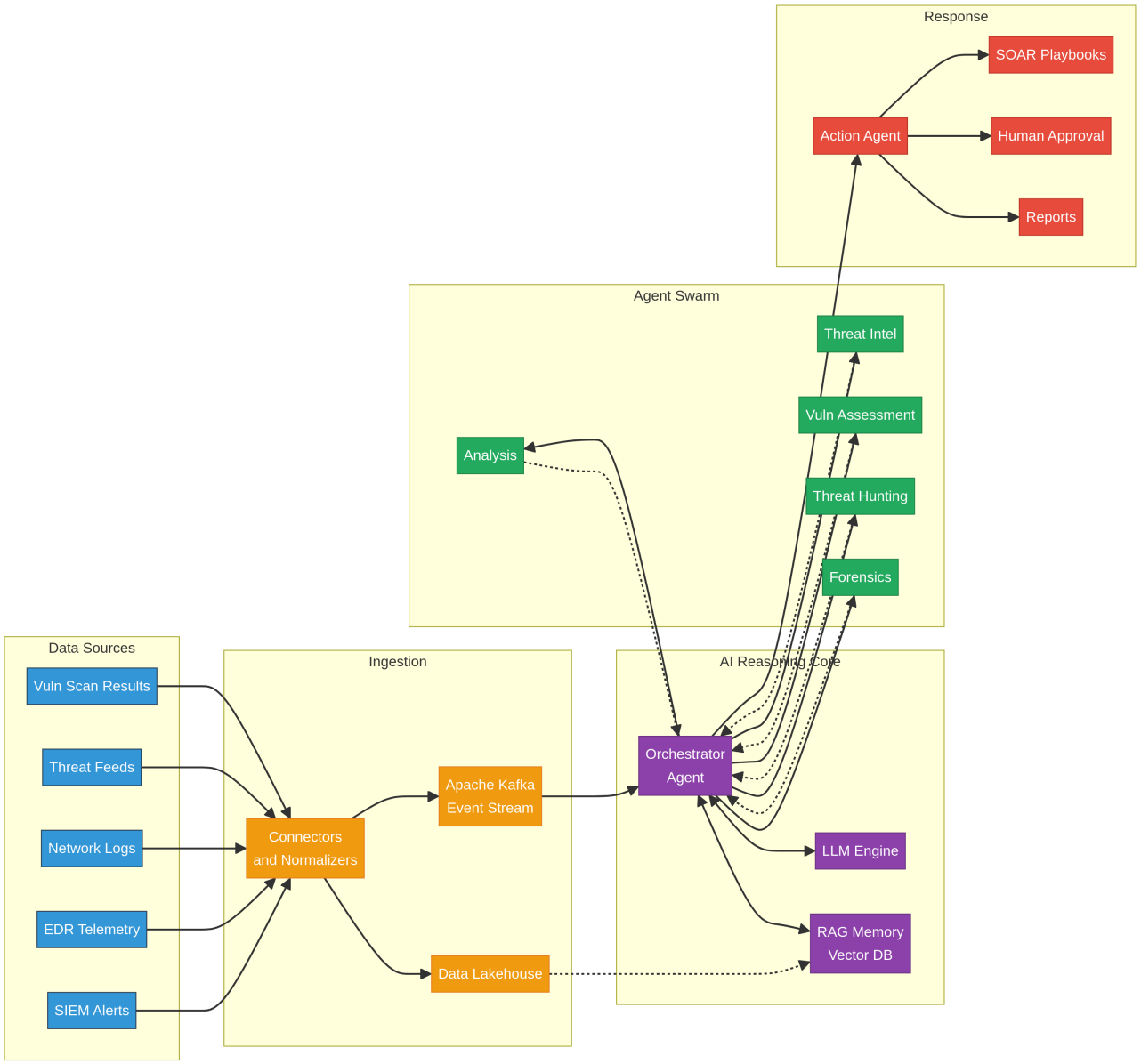

Figure 2: Data Flow and Agent Interaction. This diagram illustrates how data flows from external sources through the ingestion layer into the AI reasoning core, where the Orchestrator Agent delegates tasks to the specialized agent swarm, and ultimately drives automated responses.

Layer 5: Action and Response Layer

This layer translates the Orchestrator's decisions into concrete containment and remediation actions.

The **Action Agent** interfaces with SOAR platforms, IAM directories, and EDR APIs to execute pre-defined response actions. These may include isolating a compromised endpoint, blocking a malicious IP address at the firewall, disabling a compromised user account, or triggering a SOAR playbook for a complex, multi-step remediation

workflow. The **Automated Playbooks** module stores and executes pre-defined response workflows that can be triggered by the Action Agent or directly by the Orchestrator. The **Reporting and Communication Engine** generates human-readable incident summaries, distributes alerts via collaboration tools (Slack, Microsoft Teams), and produces compliance-ready reports.

Critically, this layer includes a **Human-in-the-Loop (HITL)** control gate. For high-impact actions — such as shutting down a production server, wiping an endpoint, or initiating a company-wide password reset — the system pauses execution and presents the human analyst with the AI's reasoning, the supporting evidence, and the proposed action for explicit approval. This ensures that the AI agent remains a powerful tool under human supervision, rather than an unchecked autonomous system.

Layer 6: Governance and Monitoring Layer

This cross-cutting layer ensures the AI system operates securely, transparently, and within defined organizational and regulatory boundaries.

The **Guardrails and Policy Engine** validates all LLM inputs and outputs. On the input side, it defends against prompt injection attacks by sanitizing and validating all data before it reaches the LLM. On the output side, it ensures that the LLM's proposed actions comply with organizational security policies and do not exceed the agent's authorized scope. The **MLSecOps Pipeline** manages the full lifecycle of the AI models, including continuous training on new threat data, drift detection to identify when model performance degrades, and adversarial robustness testing aligned with the MITRE ATLAS framework. The **Audit Trail and Compliance Logging** module records every decision, action, and data access performed by the AI agent, providing a complete, immutable audit trail for compliance and forensic purposes. The **Zero Trust Controls** module enforces the principle of least privilege for the AI agent itself, requiring authentication and authorization for every API call and data access.

3.3 Data Flow and Pipeline Design

The end-to-end data flow of the Cybersecurity AI Agent follows an asynchronous, iterative pattern designed to refine understanding as new information becomes available:

1. **Event Trigger:** A security alert is generated by an EDR, SIEM, or other monitoring tool and ingested by the Telemetry Connectors.
2. **Normalization and Routing:** The Data Normalizer standardizes the event and publishes it to the Event Stream Bus (Kafka). Simultaneously, raw data is persisted to the Security Data Lakehouse.
3. **Initial Assessment:** The Orchestrator Agent receives the event, queries the Memory Management module for historical context and relevant threat intelligence via RAG, and formulates an investigation plan using Chain-of-Thought reasoning.
4. **Task Delegation:** The Orchestrator assigns specific analysis tasks to the Specialized Agents (e.g., instructing the Analysis Agent to parse a suspicious PowerShell script, and the Threat Intel Agent to look up a flagged IP address).
5. **Tool Execution and Enrichment:** Specialized Agents use their integrated tools to gather and analyze data. The Threat Intel Agent queries VirusTotal and MISP; the Vulnerability Agent checks the CVE database for known exploits.
6. **Synthesis and Decision:** Specialized Agents return structured JSON findings to the Orchestrator. The Orchestrator synthesizes all inputs, determines the overall threat severity, and formulates a response strategy.
7. **Action Execution:** The Orchestrator instructs the Action Agent to execute the response. For low-impact actions (e.g., blocking an IP), execution is immediate. For high-impact actions, the HITL gate is engaged.
8. **Feedback and Learning:** The outcome of the response is recorded back into the Memory Management module and the Data Lakehouse, allowing the system to learn from each incident and improve future performance.

---

4. Technology Stack Recommendations

The following table presents the recommended technology stack for implementing the proposed architecture:

Component	Recommended Technologies	Rationale
LLM Foundation	OpenAI GPT-4o, Anthropic Claude 3.5 Sonnet, Meta Llama 3 (local)	Hybrid approach: cloud LLMs for complex reasoning; local models for sensitive data privacy
Agent Orchestration	LangGraph, CrewAI	Mature frameworks for stateful, multi-agent workflows with tool-use support
Vector Database (RAG)	Pinecone, Milvus, ChromaDB	Efficient semantic search for threat intelligence and historical incident retrieval
Event Streaming	Apache Kafka	Industry-standard for high-throughput, fault-tolerant real-time event streaming
Stream Processing	Apache Flink	Low-latency stream processing for real-time correlation and enrichment
Data Lakehouse	Apache Iceberg on S3 / Delta Lake	Cost-effective, scalable storage for historical security telemetry
Integration Protocols	REST APIs, GraphQL, STIX/TAXII, Syslog, CEF	Broad compatibility with existing security infrastructure
Containerization	Docker, Kubernetes	Isolated, scalable deployment of agent components
Monitoring and Observability	Prometheus, Grafana, OpenTelemetry	End-to-end visibility into agent performance and health

---

5. Integration Points with Existing Security Tools and Standards

The architecture is designed for seamless integration with the standard enterprise security stack. The table below maps each integration category to the specific tools and the protocol or standard used:

Integration Category	Tools	Protocol / Standard
SIEM / XDR	Microsoft Sentinel, Splunk Enterprise Security, Elastic Security	REST API, Syslog, CEF
EDR	CrowdStrike Falcon, SentinelOne, Microsoft Defender for Endpoint	REST API
Threat Intelligence	MISP, OpenCTI, Recorded Future, Mandiant	STIX/TAXII, REST API, GraphQL
Vulnerability Scanning	Tenable Nessus, OpenVAS, Nuclei	REST API
SOAR	Cortex XSOAR, Splunk SOAR, Shuffle	REST API, Webhooks
IAM / Directory	Microsoft Entra ID, Okta	SCIM, REST API
Frameworks	MITRE ATT&CK, NIST CSF, OWASP LLM Top-10, MITRE ATLAS	Knowledge base integration via RAG

---

6. AI/ML Model Considerations

Selecting and managing the AI models that power the Cybersecurity AI Agent is a critical design decision with implications for performance, cost, security, and privacy.

Model Selection Strategy: A hybrid approach is strongly recommended. Large, general-purpose LLMs (such as GPT-4o or Claude 3.5 Sonnet) should be used for the Orchestrator Agent's complex reasoning, planning, and synthesis tasks, where their broad knowledge and advanced instruction-following capabilities are most valuable. Smaller, domain-specific models — either fine-tuned open-source models (e.g., Llama 3) or purpose-built classifiers — should be deployed for high-volume, latency-sensitive tasks such as log parsing, malware classification, and alert triage. This approach optimizes the trade-off between capability, cost, and data privacy.

Fine-Tuning and Continuous Learning: The agent's effectiveness improves significantly when models are fine-tuned on organization-specific data, including historical incident reports, internal runbooks, and proprietary telemetry. A continuous learning pipeline should be established to periodically retrain models on new data,

ensuring the agent adapts to the organization's evolving threat landscape and reduces false positives over time.

Adversarial Robustness: The AI models themselves are attack surfaces. The system must implement defenses against prompt injection (where malicious input manipulates the LLM's behavior), data poisoning (where training data is corrupted to degrade model performance), and evasion attacks (where adversaries craft inputs designed to bypass detection). These defenses should be aligned with the MITRE ATLAS framework and the OWASP LLM Top-10 [16] [17].

---

7. Deployment Considerations

Containerized, Isolated Environment: All agent components should be deployed within a secure, containerized environment (e.g., Kubernetes) with strict network segmentation and egress firewall rules. As demonstrated by HackSynth's deployment model, autonomous agents must operate within defined boundaries to prevent unauthorized interactions with external systems [3].

Zero Trust for the Agent: The AI agent itself must be treated as an untrusted entity within the Zero Trust model. Every API call it makes to external security controls must be authenticated and authorized, and the agent should operate with the minimum privileges necessary for each specific task.

Scalability and High Availability: The event-driven architecture, built on Kafka and Kubernetes, supports horizontal scaling to handle surges in alert volume (e.g., during an active incident). Critical components such as the Orchestrator Agent and the Event Stream Bus should be deployed with redundancy to ensure high availability.

Compliance and Data Privacy: Organizations must ensure that the deployment complies with relevant data privacy regulations (e.g., GDPR, CCPA, HIPAA). Sensitive data should be anonymized or pseudonymized before being sent to external LLM APIs. For the most sensitive environments, locally deployed open-source models should be used exclusively.

---

8. Conclusion

The integration of agentic AI into cybersecurity operations represents a paradigm shift from reactive, human-dependent defense to proactive, autonomous threat management. The research presented in this report demonstrates that the building blocks for such systems — from mature SOAR platforms and threat intelligence feeds to cutting-edge LLM agent frameworks — are already available and rapidly maturing.

The proposed multi-agent architecture leverages these building blocks within a principled, layered design that prioritizes modularity, deep integration with existing infrastructure, and robust governance. By combining the advanced reasoning capabilities of large language models with the operational precision of specialized security tools, the Cybersecurity AI Agent can dramatically accelerate threat detection, investigation, and response — while keeping human analysts firmly in control of high-stakes decisions.

The path forward requires not only technical implementation but also organizational commitment to the governance frameworks — NIST AI RMF, OWASP LLM Top-10, MITRE ATLAS, and Zero Trust principles — that ensure these powerful systems operate safely, transparently, and in alignment with organizational and regulatory requirements.

References

[1]: Diatom Enterprises. “Best AI Cybersecurity Tools 2025.” *Diatom Enterprises Blog*, Nov. 2025. https://diatomenterprises.com/best-ai-security-tools-2025/

[2]: PentestGPT. “Autonomous Penetration Testing.” https://pentestgpt.com/

[3]: Muzsai, L., Imolai, D., & Lukacs, A. “HackSynth: LLM Agent and Evaluation Framework for Autonomous Penetration Testing.” *arXiv preprint arXiv:2412.01778*, Dec. 2024. https://arxiv.org/abs/2412.01778

[4]: Splunk. “Splunk SOAR.” https://www.splunk.com/en_us/products/splunk-security-orchestration-and-automation.html

[5]: Palo Alto Networks. “Cortex XSOAR.” https://www.paloaltonetworks.com/cortex/cortex-xsoar

[6]: IBM. “IBM QRadar SOAR.” https://www.ibm.com/products/qradar-soar

[7]: Shuffle. “Shuffle: Open Source SOAR.” https://shuffler.io/

[8]: MISP Project. “MISP Open Source Threat Intelligence Platform.” https://www.misp-project.org/

[9]: Filigran. “OpenCTI: Open Source Threat Intelligence Platform.” https://filigran.io/platforms/opencti/

[10]: Recorded Future. “Threat Intelligence.” https://www.recordedfuture.com/products/threat-intelligence

[11]: Google Cloud. “Mandiant Threat Intelligence.” https://cloud.google.com/security/products/mandiant-threat-intelligence

[12]: ThreatConnect. “Cyber Threat Intelligence and Risk Quantification.” https://threatconnect.com/

[13]: Microsoft. “Microsoft Security Copilot.” https://www.microsoft.com/en-us/security/business/ai-machine-learning/microsoft-security-copilot

[14]: Morales Aguilera, F. “Agentic AI in Cybersecurity: Enhancing Defence with LLMs.” *Medium*, Aug. 2025. https://medium.com/ai-simplified-in-plain-english/agentic-ai-in-cybersecurity-enhancing-defence-with-llms-d2e5a5fad203

[15]: NIST. “AI Risk Management Framework (AI RMF 1.0).” https://www.nist.gov/artificial-intelligence/executive-order-safe-secure-and-trustworthy-ai

[16]: OWASP. “OWASP Top 10 for Large Language Model Applications.” https://owasp.org/www-project-top-10-for-large-language-model-applications/

[17]: MITRE. “ATLAS: Adversarial Threat Landscape for AI Systems.” https://atlas.mitre.org/

[18]: Google. “Secure AI Framework (SAIF).” https://safety.google/cybersecurity-advancements/saif/